



CHALLENGE 12 / 20

THE CFO'S IMPOSSIBLE LOGIN

SESSION AUTHENTICITY AND CREDENTIAL-REPLAY ANALYSIS

NATIONAL LEVEL HACKATHON • 2026

POWERED BY SYNTHOQUEST PVT LTD

Student Project Development Challenge • No organizer-provided evidence package.

1 | PROBLEM BACKGROUND

A bank with 18,000 staff saw its CFO sign in to the treasury reporting platform from Mumbai at 10:02 and from Frankfurt at 10:11. Both passed number-matching MFA. The CFO owns two laptops and a tablet, travels weekly, uses a corporate VPN with exit nodes in six countries and often a personal hotspot. His executive assistant holds delegated access.

Both sessions downloaded board packs. The browser fingerprints differ by one minor version. The Frankfurt address belongs to a VPN range shared by 3,000 other staff. Three days earlier the identity provider issued a long-lived refresh token to a session from a hotel in Singapore. Five days ago an application was granted consent by an unknown publisher, and a mailbox rule appeared.

The security team receives about forty impossible-travel alerts a day and 98% are benign. The board meets tomorrow, and locking the CFO's account affects it.

2 | PROBLEM STATEMENT

Develop a **Session Authenticity Assessment System** that classifies every session in an account's history as genuine user, delegate, legitimate VPN routing, hijacked, replayed, device-cloned or sustained through a malicious application grant, and traces each session back to the grant or token that created it.

The system must find the original point of compromise if one exists, and do so at a false-alert rate a team receiving forty alerts a day can work with.

Hard constraints

- Authentication succeeded everywhere, including MFA.
- Token and grant lineage must be reconstructed across identity provider, applications and mailbox.
- The adversary replays from residential addresses near the victim and imitates device fingerprint and timing.
- Legitimate privacy tools, VPNs and delegates must not be flagged.
- The false-positive and false-negative trade-off must be measured, not claimed.

No evidence package or dataset is provided. Teams decide what to build, what data they need, how to simulate the environment and how to validate the result. No tools or architecture are prescribed.

3 | MANDATORY FEATURES

Teams must develop a working software solution. The system must provide the following features. How each is achieved is for the team to decide.

01	Session Lineage Reconstruction	Ability to trace every session to the grant, token or login that created it.
02	Hijack and Replay Detection	Ability to detect reuse of stolen tokens and cookies.
03	Device Clone Detection	Ability to detect cloned or emulated devices and imitated fingerprints.
04	Delegate and VPN Separation	Ability to separate delegates, VPNs and travel from compromise.
05	Malicious Grant Detection	Ability to detect persistence through application consent and rules.
06	Compromise Origin Identification	Ability to find where the compromise began.
07	Alert Burden Control	Ability to keep false alerts low enough for a real SOC.
08	Decision Justification	Ability to justify lock or no-lock to executives.

The system must clearly distinguish between:

LEGITIMATE	VPN ROUTED	HIJACKED	TOKEN REPLAY	CLONED DEVICE
------------	------------	----------	--------------	---------------

A successful authentication must not be presented as proof that the user was genuine.

Build, don't search. This is a development challenge. Teams must create the system and the controlled environment that proves it works. Submitting an analysis of a given dataset is not a solution.

4 | EXPECTED OUTPUT

Live demonstration. The team must show that its system can handle a complex controlled scenario created by the team. The demonstration must show:

01	Teams' own simulated identity environment with delegates, VPNs and travel
02	Several planted compromise paths
03	Classification of every session
04	Token and grant lineage
05	Detection of a malicious application grant
06	Measured false-positive and false-negative rates
07	A lock or no-lock decision with justification

The team must be able to explain why the system reached each major conclusion.

Validation standard (every team)

- Build a scenario generator with known ground truth and evaluate on at least ten distinct scenarios, including ones with deliberately misleading evidence.
- At the demonstration, judges change scenario parameters on the spot. The system must adapt without being rebuilt.
- Include an adversary variant that actively tries to defeat the system, and report how the system held up.
- Stated confidence must match measured accuracy. Overconfident or unexplained conclusions lose marks.
- No real systems, real personal data or functional malware may be used.

Submission. Each team must submit:

01	Working Prototype	A functional implementation of the proposed solution.
02	Source Code	Complete source code required to reproduce the project.
03	Technical Architecture	Architecture and component description.
04	Validation Environment	A controlled environment created by the team to demonstrate the solution.
05	Technical Documentation	Implementation, design and testing documentation.
06	Forensic Investigation Report	A professional report generated from the demonstrated investigation.
07	Demonstration	Live technical demonstration to the judging panel.
08	Limitations	Known limitations and situations where the system cannot establish a reliable conclusion.